

GUIA PASSO-A-PASSO: IMPLEMENTAR MFA EM 15 DIAS

Autenticação Multifactor — A medida NIS2 com maior retorno sobre investimento

Porquê o MFA é PRIORIDADE ABSOLUTA? Microsoft reporta que o MFA bloqueia 99,9% dos ataques automáticos de comprometimento de contas. Sem MFA, uma password roubada (em qualquer data breach) dá acesso imediato. **Custo: €0 se usar Microsoft 365 / Google Workspace já contratado.**

TIPOS DE MFA — DO MENOS SEGURO AO MAIS SEGURO			
■ SMS/Código por SMS	EVITAR	Vulnerável a SIM Swapping (clonagem do número). Não recomendado para sistemas críticos.	Aceitável apenas se for o único método disponível como medida temporária.
■ Email com código OTP	FRACO	Se a conta de email for comprometida, o atacante recebe o código. Evitar para sistemas críticos.	Melhor do que nada. Substituir por Authenticator App o mais rapidamente possível.
■ App Authenticator (TOTP)	BOM	Microsoft Authenticator, Google Authenticator, Authy. Código TOTP local no telemóvel — não depende de rede.	RECOMENDADO para PMEs. Gratuito, fácil de usar, compatível com tudo. Implementar IMEDIATAMENTE.
■ Push Notification com aprovação	MUITO BOM	Microsoft Authenticator com Number Matching. O utilizador aprova no telemóvel vendo o número mostrado no login.	Melhor que TOTP básico — evita MFA Fatigue Attacks. Activar no Microsoft Entra ID.
■ Chave Física FIDO2 (YubiKey)	MÁXIMO	Hardware físico (USB/NFC). Impossível de phishing. Recomendado para contas de administrador e CISO.	Custo: €50-80 por chave. Para PMEs: usar apenas para contas de admin críticas. Guardar chave de backup.

PASSO-A-PASSO: ACTIVAR MFA EM MICROSOFT 365 (mais comum em PMEs portuguesas)		
DIA 1	PREPARAÇÃO — Comunicar antes de activar	Antes de ligar o MFA, enviar email a TODOS os colaboradores explicando: - O que é o MFA e porque é obrigatório (NIS2) - Que devem instalar o Microsoft Authenticator no telemóvel - Que vão receber um pedido de configuração quando fizerem login - Contacto de suporte para ajuda (TI ou helpdesk)
DIA 1-2	INSTALAR a app Microsoft Authenticator	Enviar link directo para download: - iOS: apps.apple.com → pesquisar 'Microsoft Authenticator' - Android: play.google.com → pesquisar 'Microsoft Authenticator' - Confirmar que a app está instalada em ≥80% dos utilizadores antes de activar
DIA 3	ACTIVAR MFA no portal Microsoft Entra ID	- Aceder a: entra.microsoft.com (ou admin.microsoft.com → Azure AD) - Ir a: Utilizadores → Todos os utilizadores → Autenticação multifator - Seleccionar TODOS os utilizadores → Activar → Forçar MFA - ALTERNATIVA RECOMENDADA: Políticas de Acesso Condicional (mais avançado) - Guardar screenshot como evidência de activação

DIA 3-5	SUPORTE aos utilizadores durante o 1.º login	Cada utilizador, ao fazer o próximo login, receberá assistente de configuração: • Aceder ao email → aparece pedido de 'Configurar MFA' • Escolher 'App Authenticator' → QR code aparece • Abrir app no telemóvel → + → Conta Profissional → ler QR code • Testar enviando código de aprovação • ATENÇÃO: registar o código de recuperação de emergência em local seguro
DIA 7	VERIFICAR cobertura e resolver exceções	No portal Entra ID → Relatórios → Métodos de autenticação: • Ver % de utilizadores com MFA registado • Identificar quem não completou a configuração • Contactar directamente quem não completou • OBJECTIVO: 100% antes de avançar ao passo 5 • Documentar resultado como evidência
DIA 10-15	EXPANDIR a sistemas críticos e forçar definitivamente	Após 100% em email, activar para: • VPN (configurar MFA no servidor VPN — Cisco, Sophos, FortiClient) • ERP / CRM cloud (Salesforce, Dynamics — activar na app) • Todos os outros serviços cloud (Sage, DocuSign, etc.) • Configurar 'Acesso Condicional' para bloquear login sem MFA • Registo final: screenshot de todos os sistemas com MFA activo

MFA NOUTROS SISTEMAS COMUNS EM PMEs PORTUGUESAS		
Sistema	Como Activar MFA	Custo
Google Workspace	admin.google.com → Segurança → Autenticação → MFA (seleccionar '2 passos obrigatório')	Gratuito — incluído
Sage Cloud / Conta Sage	Entrar em sage.com → Perfil → Segurança → Activar verificação em 2 etapas	Gratuito — incluído
Salesforce	Setup → Identidade → Verificação de identidade → Activar e definir como obrigatório	Gratuito — incluído
VPN WireGuard / OpenVPN	Integrar com Authelia ou Duo Security como camada MFA sobre a VPN	Duo: gratuito até 10 utilizadores
Sophos Firewall (portal admin)	Admin → Autenticação → Two-Factor Authentication → Activar TOTP	Gratuito — incluído
Servidores Windows Server	Active Directory → Policy → Account → Smart Card required / Entra ID MFA	Entra ID P1: €6/user/mês
NAS Synology	DSM → Painel de Controlo → Utilizador → Verificação em 2 etapas	Gratuito — incluído no DSM

■ CHECKLIST DE CONCLUSÃO — MFA 100% IMPLEMENTADO
Marque cada item e guarde este documento como evidência para o CNCS
■ 100% dos utilizadores com MFA registado (screenshot do relatório Entra ID / Google Admin)
■ MFA activo no email corporativo (Microsoft 365 / Google Workspace)
■ MFA activo na VPN e todos os acessos remotos
■ MFA activo no ERP, CRM e todos os sistemas cloud críticos
■ Contas de administrador com YubiKey ou MFA reforçado
■ Utilizadores formados — sabem o que fazer se perderem o telemóvel (procedimento de recuperação)
■ Código de recuperação de emergência guardado em cofre de passwords ou local seguro

■ Data de activação e screenshot arquivados em /NIS2/MFA/Activacao_[Data].pdf